

HTTP Cookies & Sessions

How websites remembers users



The Problem



- HTTP is stateless - each request is independent.
- The server does not remember any information about previous requests.
- So, without cookies and sessions, websites cannot identify users or maintain their state.

What are Cookies?

Cookies are small pieces of data stored in the user's browser as key-value pairs. They are sent automatically with every request to the same domain.



- Stored in browser (client-side)
- Used to store non-sensitive data
- Have an expiry time
- Sent with every request

For Example

```
name = Sakshi
name = Shiloni
language = en
theme = dark
```

What are Sessions?

A session stores user data on the server and links it to a unique session ID, which is usually stored in a cookie on the client side.

- Session ID is generated for each user
- Actual user data is stored on server (memory for database)
- More secure than cookies
- Used to manage user authentication and maintain state

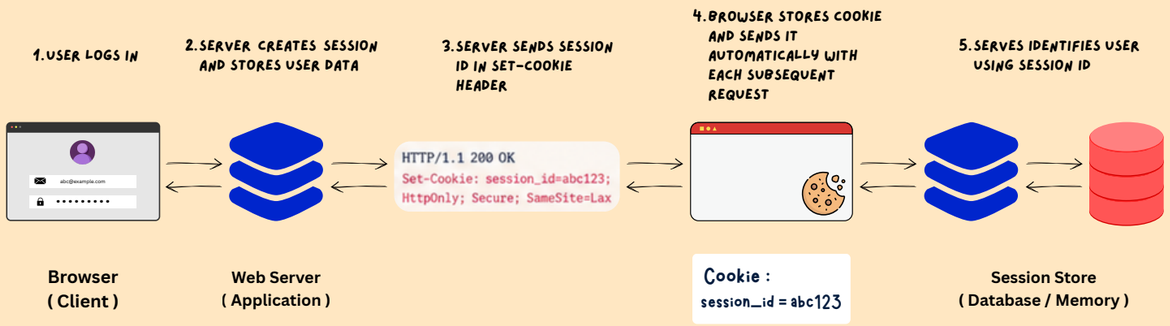


Key Differences

Features	Cookies	Sessions
Where stored?	Client (Browser)	Servive (Database / Memory)
Data type	Small, non-sensitive	Sensitive user data
Size	~ 4KB	Larger (depends on server)
Expiry	Set by expiry time	Ends when session is destroyed
Security	Less secure	More secure
Use case	Store preferenecs, theme, language	Login state, user authentication

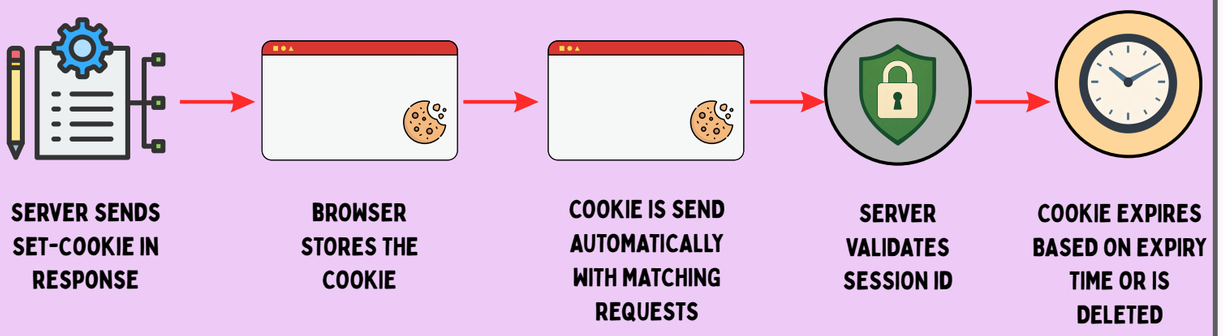
Browser–Server flow

How cookies and sessions work together



Cookie Lifecycle

From creation to expiry



Code Example </>

Example of Set-Cookie header in an HTTP response :

```
HTTP/1.1 200 OK
Set-Cookie: session_id=abc123;
Path=/; HttpOnly; Secure; SameSite=Lax
```

- **HttpOnly -** prevents access to the cookie via JavaScript (reduce XSS risk)
- **Secure -** cookie is sent only over HTTPS
- **SameSite = Lax -** helps prevent CSRF attacks

Security Practices

- **Use HTTPS -** send cookies only over secure connections
- **Set HttpOnly -** prevents access to cookies via JavaScript
- **Use SameSite -** helps prevent CSRF attacks (SameSite=Lax or Strict)
- **Set expiry time -** automatically expire inactive sessions
- **Regenerate session ID after login -** prevents session fixation attacks
- **Do not store sensitive data in cookies -** store only the session ID

Real–World Applications

Login persistence
Keep users logged in across pages

Shopping cart
Remember items added to cart

Use preferences
Store theme, language, layout and display settings

Personalized content
Show relevant recommendations based on our activity

Key features



- HTTP is stateless; it does not remember previous requests
- Cookies store small data on client side
- Sessions store user data on the server side
- Cookies and Sessions work together to maintain a continous user experience
- Security measures (HTTPS, HttpOnly, SameSite, expiry) are essential to protect users